

Marco Integrativo GQM + PRAGMATIC para Indicadores MITRE ATT&CK a Nivel Nacional

1. Introducción

Este documento define un marco integrativo que combina la metodología **Goal–Question–Metric (GQM)** con la evaluación **PRAGMATIC** para diseñar, evaluar y gobernar indicadores de ciberseguridad basados en MITRE ATT&CK aplicables a objetivos nacionales (por ejemplo, España en el contexto europeo).[web:29][web:66][web:43]

Se parte de la tendencia internacional a usar MITRE ATT&CK como base para medir cobertura de tácticas/técnicas, calidad de detección, tiempos de respuesta y alineación con el panorama de amenazas recogido por ENISA y las evaluaciones Enterprise de MITRE.[web:16][web:22][web:66]

2. Metodología GQM

2.1 Esquema general

- **Goal (Objetivo):** Qué resultado estratégico se desea lograr (p. ej., “Incrementar la resiliencia nacional frente a ataques de movimiento lateral”).
- **Question (Pregunta):** Qué necesitamos saber para saber si avanzamos hacia ese objetivo (p. ej., “¿Qué porcentaje de técnicas de movimiento lateral relevantes son detectadas a tiempo?”).
- **Metric (Métrica):** Qué datos cuantitativos/qualitativos vamos a recoger (p. ej., “Porcentaje de técnicas de la táctica Lateral Movement con detecciones activas y probadas”).[web:29][web:66]

2.2 Aplicación al contexto nacional

El GQM se aplica en tres niveles:

1. Nivel nacional / estratégico:

2.

Objetivos de resiliencia y reducción de riesgo a escala país, alineados con estrategias nacionales y marcos europeos (NIS2, DORA, ENISA ETL).[web:66][web:43]

3.

Nivel sectorial / crítico:

4.

Objetivos para sectores clave (energía, salud, administración, OT, financiero...).

5.

Nivel organizativo / técnico:

6. Métricas concretas de cobertura ATT&CK, tiempos de respuesta, calidad de detecciones, uso de CTI, etc., que alimentan los niveles superiores.[web:16][web:22][web:26]

Objetivos de resiliencia y reducción de riesgo a escala país, alineados con estrategias nacionales y marcos europeos (NIS2, DORA, ENISA ETL).[web:66][web:43]

Nivel sectorial / crítico:

Objetivos para sectores clave (energía, salud, administración, OT, financiero...).

Nivel organizativo / técnico:

3. Criterios PRAGMATIC

3.1 Definición de criterios

Cada métrica se evalúa con nueve criterios PRAGMATIC, en una escala de 0 a 5:

7. P – Predictivo: la métrica anticipa problemas o tendencias de riesgo.
8. R – Relevante: está vinculada directamente con objetivos de negocio o nacionales.
9. A – Accionable: su variación lleva a decisiones claras (inversión, cambios, priorización).
10. G – Genuino: refleja la realidad, sin inducir comportamientos perversos o “gaming”.
11. M – Significativo (Meaningful): es comprensible y aporta valor a interlocutores clave.
12. P – Preciso (Precise): tiene una definición clara y se puede medir de forma consistente.
13. T – Oportuno (Timely): puede medirse con la frecuencia necesaria para tomar decisiones.
14. I – Independiente: no está excesivamente correlacionada con otras métricas del set.
15. C – Rentable (Cost-effective): el coste de medida es razonable respecto al valor aportado.

3.2 Escala de valoración

- 0: No cumple el criterio.
- 1: Cumplimiento muy débil.
- 2: Cumplimiento parcial.
- 3: Cumplimiento razonable.
- 4: Cumplimiento fuerte.
- 5: Cumplimiento excelente.

Se puede utilizar la suma (0–45) o la media (0–5) para comparar métricas.

4. Conjunto de indicadores MITRE ATT&CK (resumen)

A partir del informe previo, se seleccionan los siguientes **indicadores nucleares**:

16. Cobertura de tácticas ATT&CK prioritarias a nivel país.
17. Cobertura de técnicas ATT&CK relevantes (por sector / por país).[web:29][web:66]
18. Brecha entre cobertura declarada y cobertura validada (tras ejercicios, pruebas, incidentes).[web:16][web:22]
19. Calidad de detección (falsos positivos / contexto) para técnicas clave.[web:16][web:60]
20. Porcentaje de alertas críticas etiquetadas con ATT&CK.
21. MTTD, MTTC y MTTR por táctica/técnica crítica (credenciales, movimiento lateral, exfiltración...).[web:26][web:66]
22. Uso de CTI con mapeo ATT&CK y priorización según ENISA ETL 2025.[web:66][web:43]
23. Porcentaje de incidentes nacionales mapeados a ATT&CK y distribución de tácticas frecuentes.[web:66]
24. Porcentaje de herramientas y servicios gestionados alineados con ATT&CK (soporte nativo, dashboards, heatmaps).[web:23][web:16]
25. Índice Global de Madurez ATT&CK (IGM) agregado.
26. ROI estimado de iniciativas ATT&CK-driven (mejoras de detección, automatización, etc.).[web:50][web:53]

5. Estructura GQM + PRAGMATIC

Para cada indicador se definen:

- Objetivo(s) nacional(es) asociado(s).
- Preguntas GQM.
- Métrica(s) concreta(s).
- Evaluación PRAGMATIC (0–5 por criterio).

La matriz detallada se desarrolla en el archivo “Matriz de Evaluación PRAGMATIC Completa”.